SPIKA TECH™

INFORME DE ANÁLISIS Y GESTIÓN DE RIESGOS

HISTORIAL DEL DOCUMENTO			
Versión	**Resumen de modificaciones**	**Fecha de entrada**	**Sustituye a (Código, revisión)**
01	Primera versión del documento.	11/03/2025	N/A
02	Añadida la fórmula que se usa para calcular el nivel de riesgo.	10/04/2025	01

REGISTRO DE FIRMAS			
Función:	**Elaborado por:**	**Revisado por:**	**Aprobado por:**
Departamento:	Responsable del SGSI	Dirección	Jefe de seguridad (o suplente)
Nombre:	David Pozo	Carlos Rodrigo	Carlos Zúñiga
Firma:	Firmado por POZO SANCHEZ DAVID - ***6992** el día 10/04/2025	Firmado por RODRIGO RIVERO, CARLOS (AUTENTICACIÓN) el día 10/04/2025 con	Firmado por ***8264** CARLOS ZUÑIGA (R: ****8690*) el día 10/04/2025 con un
Fecha:	10/04/2025	10/04/2025	10/04/2025

CONTENIDO

1 INTRODUCCIÓN 4
2 ALCANCE 5
3 NORMATIVA APLICABLE 5
4 DATOS DE PARTIDA 5
4.1 INVENTARIO DE ACTIVOS 5
4.2 LISTADO DE AMENAZAS 6
4.3 NIVEL DE MADUREZ 7
5 RESULTADOS 11
5.1 AMENAZAS CON NIVEL DE IMPACTO Y PROBABILIDAD ELEVADA 11
5.2 AMENANZAS CON PROBABILIDAD BAJA Y NIVEL DE IMPACTO ELEVADO 12
5.3 AMENANZAS CON PROBABILIDAD BAJA Y NIVEL DE IMPACTO BAJO 12
5.4 ACTIVOS CON NIVEL DE RIESGO MAJOR (9-12) 13
5.5 ACTIVOS CON NIVEL DE RIESGO CRITICAL (12-16) 15
6 PLAN DE TRATAMIENTO DE RIESGOS 17

1 INTRODUCCIÓN

Se ha realizado un análisis formal de riesgos del Sistema de Información de SPIKA TECH conforme a los requisitos de la norma **ISO/IEC 27001**:2022, específicamente en lo relacionado con la **evaluación y tratamiento de riesgos** (Cláusula 6.1.2 y Anexo A). Este análisis sigue las mejores prácticas reconocidas en el ámbito de la seguridad de la información.

La metodología utilizada para el análisis y la gestión de riesgos ha sido **MAGERIT (Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información) v3.0**, que es plenamente compatible con los principios de la ISO/IEC 27001.

Los niveles de riesgos tomados en consideración para la realización del análisis de riesgos se calculan multiplicando la probabilidad de que suceda el riesgo por el impacto que tendría en el caso de que suceda. Primero se establecen valores del 1 al 4 para la probabilidad y el impacto, para posteriormente multiplicar esos valores.

Con estos valores, los niveles de riesgo son los siguientes:

- **Riesgo CRITICAL (de 12 a 16)**: Los activos con esta combinación de impacto y probabilidad son altamente críticos y deben ser tratados con urgencia para reducir el impacto potencial de las amenazas. Este nivel se genera cuando el **Impacto** es **"A"** (severamente alto) y la **probabilidad** es alta.

- **Riesgo MAJOR (de 9 a 12)**: Estos activos presentan un riesgo importante, que puede tener un impacto negativo significativo en la seguridad o la operación, aunque no tan grave como los riesgos críticos. Generalmente, estos niveles ocurren cuando el **Impacto** es **"M"** (alto) con una probabilidad también considerable.

- **Riesgo MINOR (de 4 a 8)**: Estos riesgos son manejables y no presentan una amenaza inmediata a las operaciones. A menudo, el **Impacto** en estos casos es **"B"** (medio) o el **Impacto** es **"M"** pero con una baja probabilidad de ocurrencia.

- **Riesgo LIMITED (de 1 a 3)**: Los riesgos limitados son aquellos con **Impacto** bajo y **probabilidad** baja. Estos no suelen afectar significativamente las operaciones del sistema, pero aun así deben ser monitoreados.

Impact						
A	4	4	8	12	16	
M	3	3	6	9	12	
B	2	2	4	6	8	
MB	1	1	2	3	4	
		1	2	3	4	
		MB	B	M	A	Probability

2 ALCANCE

El presente análisis afecta a todos los activos que quedan bajo el alcance del Sistema de Información de SPIKA TECH.

3 NORMATIVA APLICABLE

Es aplicable toda la normativa establecida en el documento de **RGS_1 NORMATIVA APLICABLE**, que se actualizara de forma periódica Las Políticas, Normas y Procedimientos dentro del alcance.

4 DATOS DE PARTIDA

4.1 INVENTARIO DE ACTIVOS

Se ha realizado un inventario pormenorizado de los activos, y posteriormente, estos han sido clasificados y agrupados bajo una categoría específica denominada 'asset type'.

ID	Assets	Asset Type
AS01	Personal Directivo	[P] Personal
AS02	Usuario Final	[P] Personal
AS03	Usuarios administradores	[P] Personal
AS04	Usuarios Cloud	[P] Personal
AS05	Proveedores Desarrollo	[PRV] Proveedores
AS06	Proveedores Infraestructura y Comunicaciones	[PRV] Proveedores
AS07	Red inalámbrica	[COM] Comunicaciones
AS08	Proxy CloudFare (VRcardio)	[SE] Servicios Externos
AS09	WAF	[HW] Hardware
AS10	router, WAP)	[HW] Hardware
AS11	Maquina de Salto	[HW] Hardware
AS12	Desktop	[HW] Hardware
AS13	Laptop	[HW] Hardware
AS14	Mobile	[HW] Hardware
AS15	DNS	[SW] Software
AS16	Aplicaciones de escritorio	[SW] Software
AS17	VR-CARDIO	[SW] Software
AS18	Visual Cardio	[SW] Software
AS19	Magallanes	[SW] Software
AS20	Plataforma comercial	[SW] Software
AS21	SFTP	[SW] Software
AS22	Sedes	[L] Ubicaciones
AS23	Salas técnicas	[L] Ubicaciones
AS24	Datos de negocio	[D] Datos
AS25	Datos de gestión interna	[D] Datos
AS26	Datos de carácter personal	[D] Datos
AS27	Copias de seguridad	[D] Datos
AS28	Registros de actividad (logs)	[D] Datos

4.2 LISTADO DE AMENAZAS

ID	Threats
TH01	[Desastre] Fuego, agua o desastres naturales
TH02	[Actividad malintencionada / abuso] Fuga de información
TH03	[Actividad malintencionada / abuso] Introducción de falsa información
TH04	[Actividad malintencionada / abuso] Alteración de la información
TH05	[Actividad malintencionada / abuso] Destrucción de información
TH06	[Actividad malintencionada / abuso] Interceptación de información (escucha)
TH07	[Malfuncionamiento] Corte del suministro eléctrico
TH08	[Desastre] Condiciones inadecuadas de temperatura o humedad
TH09	[Malfuncionamiento] Fallo de servicios de comunicaciones
TH10	[Indisponibilidad del recurso] Interrupción de servicios y suministros esenciales
TH11	[Desastre] Desastres industriales
TH12	[Daños accidentales] Errores de los usuarios
TH13	[Daños accidentales] Errores del administrador
TH14	[Daños accidentales] Errores de configuración
TH15	[Daños accidentales] Degradación de los soportes de almacenamiento de la información
TH16	[Actividad malintencionada / abuso] Instalación de software dañino
TH17	[Daños accidentales] Errores de mantenimiento / actualización de programas (software)
TH18	[Indisponibilidad del recurso] Caída del sistema por sobrecarga
TH19	[Daños accidentales] Pérdida de equipos
TH20	[Indisponibilidad del recurso] Indisponibilidad del personal
TH21	[Actividad malintencionada / abuso] Abuso de privilegios de acceso
TH22	[Actividad malintencionada / abuso] Acceso no autorizado
TH23	[Actividad malintencionada / abuso] Denegación de servicio
TH24	[Actividad malintencionada / abuso] Extorsión
TH25	[Actividad malintencionada / abuso] Ingeniería social

4.3 NIVEL DE MADUREZ

Se han implementado los controles establecidos por la norma ISO 27001, asegurando su cumplimiento en todos los aspectos relevantes. Además, se ha llevado a cabo una evaluación del nivel de madurez para cada uno de estos controles, con el fin de medir su efectividad y determinar las áreas de mejora necesarias para optimizar el sistema de gestión de la seguridad de la información.

Para ello, se ha tenido en cuenta la siguiente tabla de equivalencias:

NIVEL	DESCRIPTOR	DESCRIPCIÓN
1	Inexistente	Total falta de un proceso reconocible. La organización ni siquiera ha reconocido que hay un problema que resolver.
2	Iniciado	Hay evidencia de que la organización ha reconocido que los problemas existen y que necesitan ser resueltos. Sin embargo, no hay procesos estandarizados pero en cambio hay métodos ad hoc que tienden a ser aplicados en forma individual o caso por caso.
3	Definido	Los procedimientos han sido estandarizados y documentados, y comunicados a través de capacitación. Sin embargo se ha dejado en manos de la persona el seguimiento de estos procesos, y es improbable que se detecten desviaciones.
4	Gestionado	Es posible monitorear y medir el cumplimiento de los procedimientos y emprender acción donde los procesos parecen no estar funcionando efectivamente. Los procesos están bajo constante mejoramiento y proveen buena práctica.
5	Optimizado	Los procesos han sido refinados hasta un nivel de la mejor práctica, basados en los resultados de mejoramiento continuo y diseño de la madurez con otras organizaciones. TI se usa en una forma integrada para automatizar el flujo de trabajo, suministrando herramientas para mejorar la calidad y la efectividad, haciendo que la empresa se adapte con rapidez

Eficacia de la Salvaguarda		Descripción
Valor cualitativo	**Valor cuantitativo**	
L0 - Inexistente	**0**	Esta medida no existe o no se está siendo aplicada en este momento.
L1 - Inicial/ad-hoc	**10%**	En el nivel L1 de madurez, el proceso existe, pero no se gestiona. Cuando la organización no proporciona un entorno estable. El éxito o fracaso del proceso depende de la competencia y buena voluntad de las personas y es difícil prever la reacción ante una situación de emergencia. En este caso, las organizaciones exceden con frecuencia presupuestos y tiempos de respuesta. El éxito del nivel L1 depende de tener personal de alta calidad.
L2 - Reproducible, pero intuitivo	**50%**	En el nivel L2 de madurez, la eficacia del proceso depende de la buena suerte y de la buena voluntad de las personas. Existe un mínimo de planificación que proporciona una pauta a seguir cuando se repiten las mismas circunstancias. Es impredecible el resultado si se dan circunstancias nuevas. Todavía hay un riesgo significativo de exceder las estimaciones de coste y riesgo.

L3 - Proceso definido	**80%**	Se dispone un catálogo de procesos que se mantiene actualizado. Estos procesos garantizan la consistencia de las actuaciones entre las diferentes partes de la organización, que adaptan sus procesos particulares al proceso general. Hay normativa establecida y procedimientos para garantizar la reacción profesional ante los incidentes. Se ejerce un mantenimiento regular. Las oportunidades de sobrevivir son altas, aunque siempre queda el factor de lo desconocido (o no planificado). El éxito es algo más que buena suerte: se merece. Una diferencia importante entre el nivel 2 y el nivel 3 es la coordinación entre departamentos y proyectos, coordinación que no existe en el nivel 2, y que se gestiona en el nivel 3.
L4 - Gestionado y Medible	**90%**	Cuando se dispone de un sistema de medidas y métricas para conocer el desempeño (eficacia y eficiencia) de los procesos. La Dirección es capaz de establecer objetivos cualitativos a alcanzar y dispone de medios para valorar si se han alcanzado los objetivos y en qué medida. En el nivel L4 de madurez, el funcionamiento de los procesos está bajo control con técnicas estadísticas y cuantitativas. La confianza es cuantitativa, mientras que en el nivel L3, la confianza era solamente cualitativa.
L5 - Optimizado	**100%**	**Optimizado.** El nivel L5 de madurez se centra en la mejora continua de los procesos con mejoras tecnológicas incrementales e innovadoras. Se establecen objetivos cuantitativos de mejora. Y se revisan continuamente para reflejar los cambios en los objetivos de negocio, utilizándose como indicadores en la gestión de la mejora de los procesos. En este nivel la organización es capaz de mejorar el desempeño de los sistemas a base de una mejora continua de los procesos basada en los resultados de las medidas e indicadores.

ID	Controls	Assessment Maturity 2024
C001	Políticas de seguridad de la información	3
C002	Roles y segregación de responsabilidades	3,5
C003	Contacto con las autoridades y grupos de interés	2
C004	Inteligencia de amenazas	2

C005	Seguridad de la información en la gestión de proyectos	3
C006	Inventario de información y otros activos	4
C007	Uso aceptable de la información y otros activos	3,5
C008	Devolución de activos	3
C009	Clasificación y etiquetado de la información	3
C010	Transferencia de información	3,5
C011	Gestión de identidades y control de acceso	3
C012	Información de autenticación	3
C013	Derechos de acceso	3
C014	Gestión de la seguridad de la información en relaciones con terceros	3
C015	Monitorización, revisión y gestión del cambio de servicios de terceros	3
C016	Seguridad de la información para el uso de servicios en cloud	3
C017	Planificación y respuesta para la gestión de incidentes	3
C018	Evaluación y decisión de eventos de seguridad	3
C019	Aprendizaje de los incidentes de seguridad	3
C020	Recogida de evidencias	3
C021	Seguridad de la información durante una interrupción	3
C022	Preparación de IT para la continuidad del negocio	3
C023	Requerimientos contractuales legales y regulatorios - Identificar y documentar los requisitos pertinentes	4
C024	Derechos de propiedad intelectual	3,5
C025	Protección de registros	3
C026	Privacidad y protección de la información personal	3,5
C027	Revisión independiente de la seguridad de la información	3
C028	Cumplimiento de políticas, normas, procesos operativos y estándares de seguridad	3
C029	Screening	3
C030	Términos y condiciones	3
C031	Concienciación y training sobre seguridad de la información	3,5
C032	Proceso disciplinario	2
C033	Responsabilidades a la finalización de la relación laboral	3
C034	Confidencialidad o NDAs	4
C035	Teletrabajo	2,5
C036	Reporting de eventos de seguridad - Notifiación por los canales adecuados	3,5
C037	Perímetros físicos de seguridad	2,5
C038	Entrada física	2,5
C039	Seguridad en oficinas e instalaciones.	2,5
C040	Monitoreo de seguridad física	2
C041	Protección ante amenazas físicas y medioambientales	3
C042	Mesas y escritorios limpios	3
C043	Protección del equipamiento	3
C044	Seguridad de los activos off-premises	3
C045	Dispositivos de almacenamiento	3,5
C046	Servicios de apoyo	3
C047	Seguridad en el cableado	3
C048	Mantenimiento de equipos	3
C050	Endpoints para usuarios	3
C051	Derechos de acceso privilegiados	3
C052	Restricción de acceso a la información	2,5
C053	Acceso al código fuente	3
C054	Autenticación segura	3
C055	Gestión de capacidades	3
C056	Protección contra el malware	2,5

C057	Gestión de vulerabilidades técnicas	3
C058	Gestión de configuración	3
C059	Borrado de información	3
C060	Data masking	3
C061	Prevención de exfiltración de datos	2
C062	Backups	3
C063	Redundancia de las instalaciones de procesamiento de la información	2
C064	Logging	2
C065	Actividades de monitorización	2,5
C066	Sincronización de reloj	3
C067	Uso de programas privilegiados	3
C068	Instalación de software en sistemas operativos - Procedimientos para la instalación de SW	3
C069	Seguridad en la red	2,5
C070	Segregación de redes	2,5
C071	Web filtering	3
C072	Uso de la criptografía	2,5
C073	Ciclo de vida del desarrollo seguro	3,5
C074	Requerimientos de seguridad en las aplicaciones	3,5
C075	Arquitectura de sistemas seguros y principios de ingeniería	3
C076	Secure coding	3
C077	Pruebas de seguridad en desarrollo y aceptación	3
C078	Desarrollo externalizado	3
C079	Separación de desarrollo, test y producción	3
C080	Gestión del cambio	3
C081	Test information	3
C082	Protección de los sistemas de información durante las auditorías	3

5 RESULTADOS

5.1 AMENAZAS CON NIVEL DE IMPACTO Y PROBABILIDAD ELEVADA

Las **amenazas** del sistema de información de SPIKA TECH identificadas con Probabilidad **alta** (3,0 – 4,0) e impacto **alto** (3,0-4,0), son las que siguen:

ID	Threats	Probabilidad	Impacto	[D] Datos	[SW] Software	[HW] Hardware	[COM] Comunicaciones	[L] Ubicaciones	[P] Personal	[PR/] Proveedores	[SE] Servicios Externos
TH02	[Actividad malintencionada / abuso] Fuga de información	3	4	x						x	
TH06	[Actividad malintencionada / abuso] Interceptación de información (escucha)	3	4	x							
TH16	[Actividad malintencionada / abuso] Instalación de software dañino	3	3		x					x	
TH21	[Actividad malintencionada / abuso] Abuso de privilegios de acceso	3	4		x			x		x	
TH22	[Actividad malintencionada / abuso] Acceso no autorizado	3	4		x	x	x	x		x	
TH23	[Actividad malintencionada / abuso] Denegación de servicio	3	3		x	x	x			x	
TH25	[Actividad malintencionada / abuso] Ingeniería social	4	4						x		x

5.2 AMENANZAS CON PROBABILIDAD BAJA Y NIVEL DE IMPACTO ELEVADO

Las **amenazas** del sistema de información de SPIKA TECH identificadas con Probabilidad **baja** (1,0 – 2,0) e impacto **alto** (3,0-4,0), son las que siguen:

ID	Threats	Probabilidad	Impacto	[D] Datos	[SW] Software	[HW] Hardware	[COM] Comunicaciones	[L] Ubicaciones	[P] Personal	[PRV] Proveedores	[SE] Servicios Externos
TH01	[Desastre] Fuego, agua o desastres naturales	1	4			x		x			
TH03	[Actividad malintencionada / abuso] Introducción de falsa información	2	3	x							
TH10	[Indisponibilidad del recurso] Interrupción de servicios y suministros esenciales	2	3		x		x				
TH11	[Desastre] Desastres industriales	1	4			x		x	x		
TH13	[Daños accidentales] Errores del administrador	1	4						x		
TH14	[Daños accidentales] Errores de configuración	2	3		x	x					
TH15	[Daños accidentales] Degradación de los soportes de almacenamiento de la información	2	3	x							
TH17	[Daños accidentales] Errores de mantenimiento / actualización de programas (software)	2	3		x	x				x	x
TH18	[Indisponibilidad del recurso] Caída del sistema por sobrecarga	1	4			x					
TH19	[Daños accidentales] Pérdida de equipos	2	4			x					
TH24	[Actividad malintencionada / abuso] Extorsión	2	3						x		x

5.3 AMENANZAS CON PROBABILIDAD BAJA Y NIVEL DE IMPACTO BAJO

Las **amenazas** del sistema de información de SPIKA TECH identificadas con Probabilidad **baja** (1,0 – 2,0) e impacto **bajo** (1,0-2,0), son las que siguen:

ID	Threats	Probabilidad	Impacto	[D] Datos	[SW] Software	[HW] Hardware	[COM] Comunicaciones	[L] Ubicaciones	[P] Personal	[PRV] Proveedores	[SE] Servicios Externos
TH04	[Actividad malintencionada / abuso] Alteración de la información	2	2	x							
TH05	[Actividad malintencionada / abuso] Destrucción de información	2	2	x							
TH07	[Malfuncionamiento] Corte del suministro eléctrico	1	2			x		x			
TH08	[Desastre] Condiciones inadecuadas de temperatura o humedad	1	2			x					
TH09	[Malfuncionamiento] Fallo de servicios de comunicaciones	2	2				x				
TH12	[Daños accidentales] Errores de los usuarios	2	2						x		
TH20	[Indisponibilidad del recurso] Indisponibilidad del personal	1	2						x		x

5.4 ACTIVOS CON NIVEL DE RIESGO MAJOR (9-12)

				Inherent Risk			
Asset ID	Asset	Threat ID	Threat	PROB	IMP	RISK	LEVEL
AS01	Personal Directivo	TH24	[Actividad malintencionada / abuso] Extorsión	2,0	3,0	6,0	MAJOR
AS02	Usuario Final	TH24	[Actividad malintencionada / abuso] Extorsión	2,0	3,0	6,0	MAJOR
AS03	Usuarios administradores	TH24	[Actividad malintencionada / abuso] Extorsión	2,0	3,0	6,0	MAJOR
AS04	Usuarios Cloud	TH25	[Actividad malintencionada / abuso] Ingeniería social	2,5	2,5	6,3	MAJOR
AS05	Proveedores Desarrollo	TH22	[Actividad malintencionada / abuso] Acceso no autorizado	2,5	2,5	6,3	MAJOR
AS06	Proveedores Infraestructura y Comunicaciones	TH17	[Daños accidentales] Errores de mantenimiento / actualización de programas (software)	2,0	3,0	6,0	MAJOR
AS06	Proveedores Infraestructura y Comunicaciones	TH23	[Actividad malintencionada / abuso] Denegación de servicio	3,0	3,0	9,0	MAJOR
AS08	Proxy CloudFare (VRcardio)	TH17	[Daños accidentales] Errores de mantenimiento / actualización de programas (software)	2,0	3,0	6,0	MAJOR
AS08	Proxy CloudFare (VRcardio)	TH24	[Actividad malintencionada / abuso] Extorsión	2,0	3,0	6,0	MAJOR
AS08	Proxy CloudFare (VRcardio)	TH17	[Daños accidentales] Errores de mantenimiento / actualización de programas (software)	2,0	3,0	6,0	MAJOR
AS08	Proxy CloudFare (VRcardio)	TH24	[Actividad malintencionada / abuso] Extorsión	2,0	3,0	6,0	MAJOR
AS09	WAF	TH22	[Actividad malintencionada / abuso] Acceso no autorizado	2,5	2,5	6,3	MAJOR
AS10	Elementos de soporte de red (switch, modens, hubs, router, WAP)	TH22	[Actividad malintencionada / abuso] Acceso no autorizado	2,5	2,5	6,3	MAJOR
AS11	Maquina de Salto	TH22	[Actividad malintencionada / abuso] Acceso no autorizado	2,5	2,5	6,3	MAJOR
AS12	Desktop	TH10	[Indisponibilidad del recurso] Interrupción de servicios y suministros esenciales	3,0	3,0	9,0	MAJOR
AS12	Desktop	TH14	[Daños accidentales] Errores de configuración	2,0	3,0	6,0	MAJOR
AS12	Desktop	TH17	[Daños accidentales] Errores de mantenimiento / actualización de programas (software)	2,0	3,0	6,0	MAJOR
AS12	Desktop	TH19	[Daños accidentales] Pérdida de equipos	2,0	4,0	8,0	MAJOR
AS12	Desktop	TH23	[Actividad malintencionada / abuso] Denegación de servicio	3,0	3,0	9,0	MAJOR
AS13	Laptop	TH10	[Indisponibilidad del recurso] Interrupción de servicios y suministros esenciales	3,0	3,0	9,0	MAJOR
AS13	Laptop	TH14	[Daños accidentales] Errores de configuración	2,0	3,0	6,0	MAJOR
AS13	Laptop	TH17	[Daños accidentales] Errores de mantenimiento / actualización de programas (software)	2,0	3,0	6,0	MAJOR

AS13	Laptop	TH19	[Daños accidentales] Pérdida de equipos	2,0	4,0	8,0	MAJOR
AS13	Laptop	TH23	[Actividad malintencionada / abuso] Denegación de servicio	3,0	3,0	9,0	MAJOR
AS15	DNS	TH22	[Actividad malintencionada / abuso] Acceso no autorizado	2,5	2,5	6,3	MAJOR
AS16	Aplicaciones de escritorio	TH22	[Actividad malintencionada / abuso] Acceso no autorizado	2,5	2,5	6,3	MAJOR
AS17	VR-CARDIO	TH10	[Indisponibilidad del recurso] Interrupción de servicios y suministros esenciales	3,0	3,0	9,0	MAJOR
AS17	VR-CARDIO	TH14	[Daños accidentales] Errores de configuración	2,0	3,0	6,0	MAJOR
AS17	VR-CARDIO	TH17	[Daños accidentales] Errores de mantenimiento / actualización de programas (software)	2,0	3,0	6,0	MAJOR
AS17	VR-CARDIO	TH23	[Actividad malintencionada / abuso] Denegación de servicio	3,0	3,0	9,0	MAJOR
AS18	Visual Cardio	TH10	[Indisponibilidad del recurso] Interrupción de servicios y suministros esenciales	3,0	3,0	9,0	MAJOR
AS18	Visual Cardio	TH14	[Daños accidentales] Errores de configuración	2,0	3,0	6,0	MAJOR
AS18	Visual Cardio	TH17	[Daños accidentales] Errores de mantenimiento / actualización de programas (software)	2,0	3,0	6,0	MAJOR
AS18	Visual Cardio	TH23	[Actividad malintencionada / abuso] Denegación de servicio	3,0	3,0	9,0	MAJOR
AS19	Magallanes	TH10	[Indisponibilidad del recurso] Interrupción de servicios y suministros esenciales	3,0	3,0	9,0	MAJOR
AS19	Magallanes	TH14	[Daños accidentales] Errores de configuración	2,0	3,0	6,0	MAJOR
AS19	Magallanes	TH17	[Daños accidentales] Errores de mantenimiento / actualización de programas (software)	2,0	3,0	6,0	MAJOR
AS19	Magallanes	TH23	[Actividad malintencionada / abuso] Denegación de servicio	3,0	3,0	9,0	MAJOR
AS20	Plataforma comercial	TH10	[Indisponibilidad del recurso] Interrupción de servicios y suministros esenciales	3,0	3,0	9,0	MAJOR
AS20	Plataforma comercial	TH14	[Daños accidentales] Errores de configuración	2,0	3,0	6,0	MAJOR
AS20	Plataforma comercial	TH17	[Daños accidentales] Errores de mantenimiento / actualización de programas (software)	2,0	3,0	6,0	MAJOR
AS20	Plataforma comercial	TH23	[Actividad malintencionada / abuso] Denegación de servicio	3,0	3,0	9,0	MAJOR
AS21	SFTP	TH22	[Actividad malintencionada / abuso] Acceso no autorizado	2,5	2,5	6,3	MAJOR
AS22	Sedes	TH22	[Actividad malintencionada / abuso] Acceso no autorizado	2,5	2,5	6,3	MAJOR
AS24	Datos de negocio	TH03	[Actividad malintencionada / abuso] Introducción de falsa información	2,0	3,0	6,0	MAJOR
AS24	Datos de negocio	TH15	[Daños accidentales] Degradación de los soportes de almacenamiento de la información	2,0	4,0	8,0	MAJOR
AS26	Datos de carácter personal	TH03	[Actividad malintencionada / abuso] Introducción de falsa información	2,0	3,0	6,0	MAJOR
AS26	Datos de carácter personal	TH15	[Daños accidentales] Degradación de los soportes de almacenamiento de la información	2,0	4,0	8,0	MAJOR

AS27	Copias de seguridad	TH03	[Actividad malintencionada / abuso] Introducción de falsa información	2,0	3,0	6,0	MAJOR
AS27	Copias de seguridad	TH15	[Daños accidentales] Degradación de los soportes de almacenamiento de la información	2,0	4,0	8,0	MAJOR
AS28	Registros de actividad (logs)	TH04	[Actividad malintencionada / abuso] Alteración de la información	2,5	2,5	6,3	MAJOR
AS28	Registros de actividad (logs)	TH05	[Actividad malintencionada / abuso Destrucción de información	2,5	2,5	6,3	MAJOR

5.5 ACTIVOS CON NIVEL DE RIESGO CRITICAL (12-16)

				Inherent Risk			
Asset ID	Asset	Threat ID	Threat	PROB	IMP	RISK	LEVEL
AS01	Personal Directivo	TH25	[Actividad malintencionada / abuso] Ingeniería social	4,0	4,0	16,0	CRITICAL
AS02	Usuario Final	TH25	[Actividad malintencionada / abuso] Ingeniería social	4,0	4,0	16,0	CRITICAL
AS03	Usuarios administradores	TH25	[Actividad malintencionada / abuso] Ingeniería social	4,0	4,0	16,0	CRITICAL
AS06	Proveedores Infraestructura y Comunicaciones	TH02	[Actividad malintencionada / abuso] Fuga de información	3,0	4,0	12,0	CRITICAL
AS06	Proveedores Infraestructura y Comunicaciones	TH16	[Actividad malintencionada / abuso] Instalación de software dañino	4,0	3,0	12,0	CRITICAL
AS06	Proveedores Infraestructura y Comunicaciones	TH21	[Actividad malintencionada / abuso] Abuso de privilegios de acceso	3,0	4,0	12,0	CRITICAL
AS06	Proveedores Infraestructura y Comunicaciones	TH22	[Actividad malintencionada / abuso] Acceso no autorizado	4,0	4,0	16,0	CRITICAL
AS08	Proxy CloudFare (VRcardio)	TH25	[Actividad malintencionada / abuso] Ingeniería social	4,0	4,0	16,0	CRITICAL
AS08	Proxy CloudFare (VRcardio)	TH25	[Actividad malintencionada / abuso] Ingeniería social	4,0	4,0	16,0	CRITICAL
AS12	Desktop	TH22	[Actividad malintencionada / abuso] Acceso no autorizado	4,0	4,0	16,0	CRITICAL
AS13	Laptop	TH22	[Actividad malintencionada / abuso] Acceso no autorizado	4,0	4,0	16,0	CRITICAL
AS17	VR-CARDIO	TH16	[Actividad malintencionada / abuso] Instalación de software dañino	4,0	3,0	12,0	CRITICAL
AS17	VR-CARDIO	TH21	[Actividad malintencionada / abuso] Abuso de privilegios de acceso	3,0	4,0	12,0	CRITICAL
AS17	VR-CARDIO	TH22	[Actividad malintencionada / abuso] Acceso no autorizado	4,0	4,0	16,0	CRITICAL
AS18	Visual Cardio	TH16	[Actividad malintencionada / abuso] Instalación de software dañino	4,0	3,0	12,0	CRITICAL
AS18	Visual Cardio	TH21	[Actividad malintencionada / abuso] Abuso de privilegios de acceso	3,0	4,0	12,0	CRITICAL
AS18	Visual Cardio	TH22	[Actividad malintencionada / abuso] Acceso no autorizado	4,0	4,0	16,0	CRITICAL
AS19	Magallanes	TH16	[Actividad malintencionada / abuso] Instalación de software dañino	4,0	3,0	12,0	CRITICAL
AS19	Magallanes	TH21	[Actividad malintencionada / abuso] Abuso de privilegios de acceso	3,0	4,0	12,0	CRITICAL
AS19	Magallanes	TH22	[Actividad malintencionada / abuso] Acceso no autorizado	4,0	4,0	16,0	CRITICAL
AS20	Plataforma comercial	TH16	[Actividad malintencionada / abuso] Instalación de software dañino	4,0	3,0	12,0	CRITICAL

AS20	Plataforma comercial	TH21	[Actividad malintencionada / abuso] Abuso de privilegios de acceso	3,0	4,0	12,0	CRITICAL
AS20	Plataforma comercial	TH22	[Actividad malintencionada / abuso] Acceso no autorizado	4,0	4,0	16,0	CRITICAL
AS23	Salas técnicas	TH21	[Actividad malintencionada / abuso] Abuso de privilegios de acceso	3,0	4,0	12,0	CRITICAL
AS23	Salas técnicas	TH22	[Actividad malintencionada / abuso] Acceso no autorizado	4,0	4,0	16,0	CRITICAL
AS24	Datos de negocio	TH02	[Actividad malintencionada / abuso] Fuga de información	3,0	4,0	12,0	CRITICAL
AS24	Datos de negocio	TH04	[Actividad malintencionada / abuso] Alteración de la información	4,0	4,0	16,0	CRITICAL
AS24	Datos de negocio	TH05	[Actividad malintencionada / abuso Destrucción de información	4,0	4,0	16,0	CRITICAL
AS24	Datos de negocio	TH06	[Actividad malintencionada / abuso] Interceptación de información (escucha)	3,0	4,0	12,0	CRITICAL
AS26	Datos de carácter personal	TH02	[Actividad malintencionada / abuso] Fuga de información	3,0	4,0	12,0	CRITICAL
AS26	Datos de carácter personal	TH04	[Actividad malintencionada / abuso] Alteración de la información	4,0	4,0	16,0	CRITICAL
AS26	Datos de carácter personal	TH05	[Actividad malintencionada / abuso Destrucción de información	4,0	4,0	16,0	CRITICAL
AS26	Datos de carácter personal	TH06	[Actividad malintencionada / abuso] Interceptación de información (escucha)	3,0	4,0	12,0	CRITICAL
AS27	Copias de seguridad	TH02	[Actividad malintencionada / abuso] Fuga de información	3,0	4,0	12,0	CRITICAL
AS27	Copias de seguridad	TH04	[Actividad malintencionada / abuso] Alteración de la información	4,0	4,0	16,0	CRITICAL
AS27	Copias de seguridad	TH05	[Actividad malintencionada / abuso Destrucción de información	4,0	4,0	16,0	CRITICAL
AS27	Copias de seguridad	TH06	[Actividad malintencionada / abuso] Interceptación de información (escucha)	3,0	4,0	12,0	CRITICAL

6 PLAN DE TRATAMIENTO DE RIESGOS

Se procederá a la elaboración de un plan de tratamiento de riesgos, centrado en abordar prioritariamente aquellos riesgos clasificados como 'Major' o 'Critical'. Este enfoque permitirá dirigir los recursos y esfuerzos hacia la mitigación de los riesgos más significativos, asegurando que se implementen medidas efectivas para reducir su impacto y probabilidad. El plan estará alineado con los objetivos estratégicos de la organización, garantizando una gestión proactiva y eficiente de los riesgos más críticos.